

Business Case - OS1B

Group Members:

Cong Deng	a1155047
Sheng Wang	a1903948
Tianhua Zhang	a1915934
Xin Wei	a1912958
Yifan Gu	a1909803

Executive Summary.....	1
Part 1.....	1
WHAT.....	1
WHY.....	1
GOALS.....	2
Part 2: Iteration 1 Plan.....	3
First Iteration Milestone: Command-line Prototype.....	3
Schedule & Task Duration Responsible.....	3
Product roadmap.....	3
Team Organization.....	5
Communication Plan.....	5
Internal Communication.....	5
External Communication.....	5
Documentation.....	5

Executive Summary

In the era of widespread Internet applications, software security has become crucial, with vulnerabilities causing significant losses and reputational risks. Mastering security knowledge is now essential for developers.

Traditional learning methods often lack real-world insights, leading to inefficient learning. To address this, our project builds an **Augmented Software Security Knowledge Base** based on **Retrieval-Augmented Generation (RAG)** framework, integrating domain-specific documents and developer discussions to provide practical and up-to-date security knowledge.

Part 1

WHAT

Our application is an **AI-enhanced, developer-centric knowledge base for software security learning and problem-solving**. It combines the capabilities of large language models (LLMs) with real-world security knowledge sources to deliver insights.

Compared to conventional learning methods, our knowledge base provides developers with:

1. **Insights on the most-discussed security issues** in the global developer community.
2. **Community sentiment and attitudes** toward these security challenges.
3. **Key learning challenges and required skill sets** associated with specific security topics.

One key innovation of our system apart from traditional knowledge bases and LLMs.

- **Structured, Security-Focused Response Design**

Delivers clear, structured answers tailored to software security learning with embedded domain knowledge.

WHY

Without proper security handling, companies may face economic losses, reputational damage, and even national security risks. For instance, in March 2018, a Google+ data leak went unreported until media exposure, raising concerns about Google's responsibility.

Although security is crucial, developers struggle to address threats due to the complexity of security knowledge and the difficulty of finding solutions.

Problem: Security threats in software development are increasingly critical, but developers struggle to identify and resolve them due to the complexity of security knowledge and the difficulty of finding solutions.

Opportunity: With artificial intelligence tools, security issues can be automatically identified and solved. By using knowledge of the developer community, AI can analyze security issues in the corresponding scenarios and provide useful suggestions, enhancing both the speed and accuracy of security problem solving.

Impact: By providing tools that solve security problems, it can reduce the risk of data breaches and enhance the overall security status of their applications. This tool can also be used to learn about security-related issues and improve their own technology.

GOALS

The primary objective of this project is to construct an AI-augmented security knowledge base that supports software developers by retrieving relevant community knowledge and generating insightful answers to security-related questions, enriched with sentiment analysis.

Goal 1: Construct a security topic classification model to categorize user questions. The model clarifies the security aspects involved and facilitates future development and learning.

Goal 2: Build a semantic vector index of security-related posts using pre-trained embedding models (e.g., Sentence-BERT). The system will compute vector representations of user queries and content entries, and retrieve the most semantically relevant cases in real time using cosine similarity.

Goal 3: Use VADER to perform sentiment analysis. This helps identify the emotional states (e.g., anxiety, confidence) of developers when facing various security issues.

Goal 4: Integrate an LLM-based answer generator, which is deployed locally for scalability and privacy. This module generates natural language responses, providing deeper insights and learning opportunities.

Goal 5: Develop an interactive user interface for knowledge presentation, containing challenge analysis, solution suggestions, related posts, and required skills, supported by a dynamically updated knowledge base.

Together, these goals will provide a solid foundation for a scalable, intelligent and continuously improving system that enables developers to adopt secure coding practices more efficiently.

Part 2: Iteration 1 Plan

First Iteration Milestone: Command-line Prototype

Team: OS1B

Project Title: Augmented Security Knowledge Base

Milestone 1	Activities	Projected Outputs
Deliver a MVP with simple User Interface	Set up command line tool	CLI interface to accept natural language security questions as input
	Classifier Development	Build and train a classification model to categorize questions
	Vectorized Dataset & Similarity Calculation	Build a Semantic Vector Database
	Sentiment Analysis	Sentiment/style analysis result
	LLM & Prompt	Integrate a lightweight LLM-based solution to generate summarized

Target Completion Date:

End of Week 7 (Sunday, 11:59 PM)

Acceptance Criteria:

- CLI accepts at least two input types: keywords and full questions
- Output follows defined structure

Schedule & Task Duration Responsible

Product roadmap			
Timeline	Objective	Due Date	 Status
Week 1	Understand the dataset structure and perform preprocessing on Stack Overflow data	09 March	Done ▾
Week 2	Design and run ChatGPT prompts to extract challenges and required skills	16 March	Done ▾
Week 3	Build and train an SVM classifier to categorize question types & try to use Bert for unsupervised learning	23 March	Done ▾
Week 4	Pitch Presentation & Cluster and validate ChatGPT answers into sub-categories	30 March	Done ▾

Product roadmap

Timeline	Objective	Due Date	Status
Week 5	Build up the pipeline & Business Case Documentation: 1.Set up baseline RAG with LangChain (Retriever, LLM, Prompt); 2.Modularize SVM classifier; 3.Develop sentiment analyzer; 4.Use BERTopic/LDA for topic relationship mining	06 April	In progress ▾
Week 6	Integrate all components & run the pipeline: 1.Chunk & embed Stack Overflow docs (SentenceTransformers); 2.Import vectors into store (Chroma/FAISS); 3.import SVM classifier and sentiment analyzer module; 4.Finalize RAG chain (context retrieval, prompt formatting, LLM response); 5.Construct the response data structure for the system API;	13 April	Not started ▾
Week 7	Record and analyse the results & Milestone 1 - Product Demo Delivery: 1.Run RAG pipeline & analyze results (incl. LLM comparison); 2.Assess answer clarity, structure, and usefulness; 3.Prepare product demo (examples, slides/video, talking points); 4.Submit demo & evaluation notes; confirm checklist with team;	04 May	Not started ▾
Week 8	Testing Plan and prepare final testing: 1.Design diverse test cases covering various security topics (e.g., XSS, JWT) including both typical and edge queries. 2. Define human evaluation metrics focusing on relevance, clarity, and technical usefulness.	11 May	Not started ▾
Week 9	Frontend development, Base Knowledge deployment, and their integration: 1. Build Frontend Prototype; 2. Integrate Backend Pipeline and connect frontend to LangChain pipeline (via API); 3. Display full response structure (including classification, sentiment, etc.)	18 May	Not started ▾

Product roadmap

Timeline	Objective	Due Date	 Status
Week 10	Executing Test Plan & Debugging & Bug Fixing	25 May	Not started ▾
Week 11	Report writing	01 June	Not started ▾
Week 12	Final Product Delivery & Report	08 June	Not started ▾

Team Organization

Project Manager - Cong Deng: Responsible for overseeing the entire project, ensuring milestones are met, and communicating with stakeholders.

AI Specialist - Sheng Wang & Tianhua Zhang: Focuses on developing and training the AI models.

Data Analyst - Yifan Gu: Collects and cleans data from sources like Stack Overflow and prepares it for analysis.

Quality Assurance - Xin Wei: Handles testing and ensures the system meets the necessary standards.

Communication Plan

Internal Communication

Daily standup meetings via Zoom with all group members to update our progress on each task and collect questions, blockers.

Weekly team meetings with our supervisor Orvila Sarker to review progress, identify blockers, and discuss feedback.

External Communication

Weekly progress updates for stakeholders (mainly our supervisor in our case), delivered via email or project management tools (e.g., MS Teams).

Documentation

Use shared cloud-based platforms (Google Docs, Sheets, Slides, uni github repo) for collaboration and document storage.